

Project and Lab Quiz

- ◇ Group formation
- ◇ First Lab quiz week 5 (UniAccess Student)



4. Access Control

Garrison Gao

garrison.gao@uwa.edu.au

Access Control

- ◇ To restrict access to places and resources
- ◇ Main features of Access Control includes:
 - ◇ (Authentication)
 - ◇ Authorization
 - ◇ Implementation and Audit
- ◇ Authentication verifies the user's identity, and access control uses this identity to grant or deny access.
 - ◇ So Authentication may not be needed in all circumstances
 - ◇ E.g.,?
- ◇ Access control uses the authorization process to either grant or deny access to systems or data
 - ◇ i.e., authorization defines policies on what a user or service may access.
 - ◇ Access control enforces these policies.

Access Control

- ◆ Authentication (password/crypto/etc.)

- ◆ Who are you?

- ◆ Authorization (Access control)

- ◆ What are you allowed to do.

- ◆ Focus is policy

- ◆ Enforcement Mechanism

- ◆ How its policy implemented/enforced

Night Club Example

- ◇ Authentication
 - ◇ ID Check
- ◇ Access Control
 - ◇ Over 18 - allowed in
 - ◇ Over 21 - allowed to drink
 - ◇ On VIP List - allowed to access VIP area
- ◇ Enforcement Mechanism
 - ◇ Walls, Doors, Locks, Bouncers



Online Liquor shop Example

- ◇ Authentication
 - ◇
- ◇ Access Control
 - ◇
 - ◇
 - ◇
- ◇ Enforcement Mechanism
 - ◇



Online Liquor shop Example

- ◇ Authentication
 - ◇ Age 18+ membership (e.g., ID upload, sighted at shop, etc.)
- ◇ Access Control
 - ◇ members can checkout and purchase
 - ◇ VIPs can browse VIP sales
 - ◇ Web master can update catalogue
- ◇ Enforcement Mechanism
 - ◇ Username and password
 - ◇ Security token



Other Examples

- ◇ Social Networks: Access to personal information.
- ◇ Web Browsers:
- ◇ Operating Systems:
- ◇ Memory Protection:
- ◇ Firewalls:

Other Examples

- ◇ Social Networks: Access to personal information.
- ◇ Web Browsers: Access only to a website (same origin policy).
- ◇ Operating Systems: One user cannot arbitrarily access/kill another user's files/processes.
- ◇ Memory Protection: Code in one region, cannot access the data in another more privileged region.
- ◇ Firewalls: If a packet matches with certain conditions, it will be dropped.

Access Control

- ◇ Access control fundamental concepts
- ◇ Types of access control

Access Control Types

- ◇ Definition (Microsoft): Access control is an essential element of security that determines **who** is allowed to **access** certain data, apps, and resources—and in what **circumstances**.

<https://www.microsoft.com/en-au/security/business/security-101/what-is-access-control>

Access Control Types

Discretionary access control (DAC)

- ◇ A means of assigning access rights set by the **owner** of the resource.
- ◇ Flexible

Non-Discretionary access control (NDAC)

- ◇ Based on policies set by a **central authority**. Also known as mandatory access control (MAC)
- ◇ Strict and Uniform
- ◇ E.g., HR department, employment letter from other departments

Discretionary Access Control

Two entities

- ◆ Subject, an active entity (e.g., user, process)
- ◆ Object, a passive entity (e.g., File, Folder, App, Memory, CPU/GPU)



Discretionary Access Control

```
(cits1003@ CITS1003) - [~/Downloads/CITS2006Lab/Lab3]  
$ ls -l  
total 24  
drwxrwxr-x  5 cits1003 cits1003 4096 Nov 22 17:47 cits2006_env  
-rw-rw-r--  1 cits1003 cits1003  566 Nov 23 16:07 password.py  
drwxrws---+ 3 sales      sales   4096 Nov 25 17:32 sales  
-rw-rw-r--  1 cits1003 cits1003  391 Nov 25 17:09 Task3  
-rw-rw-r--  1 cits1003 cits1003 1542 Nov 23 17:34 totp_mfa.py
```

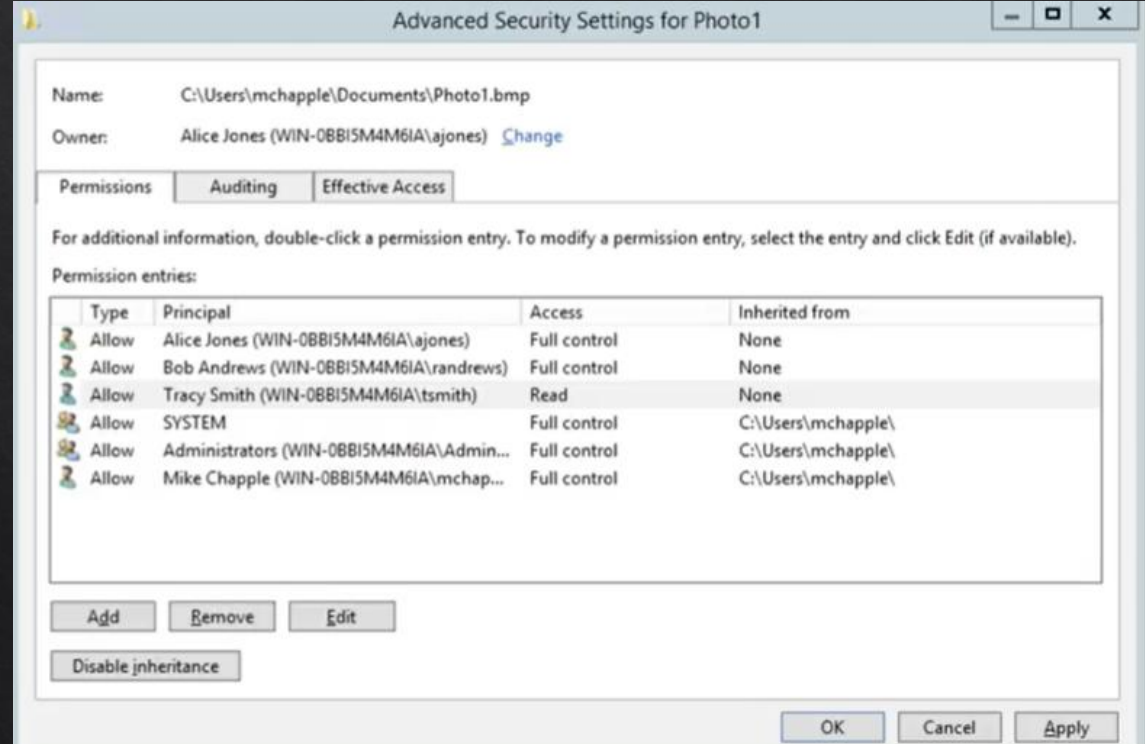
Owner: rwx

Group: rwx

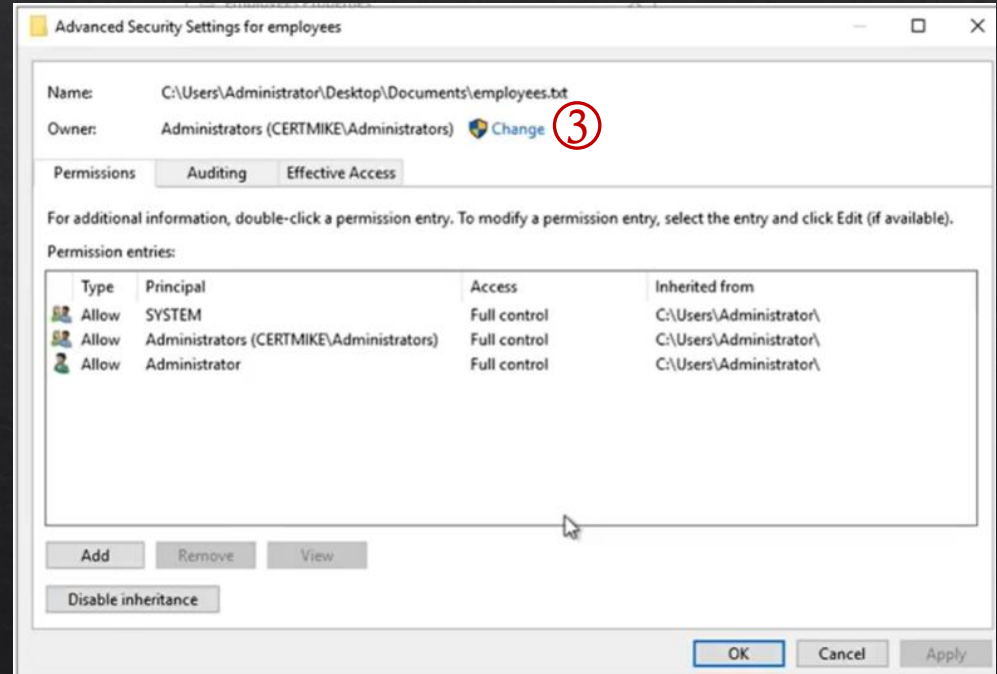
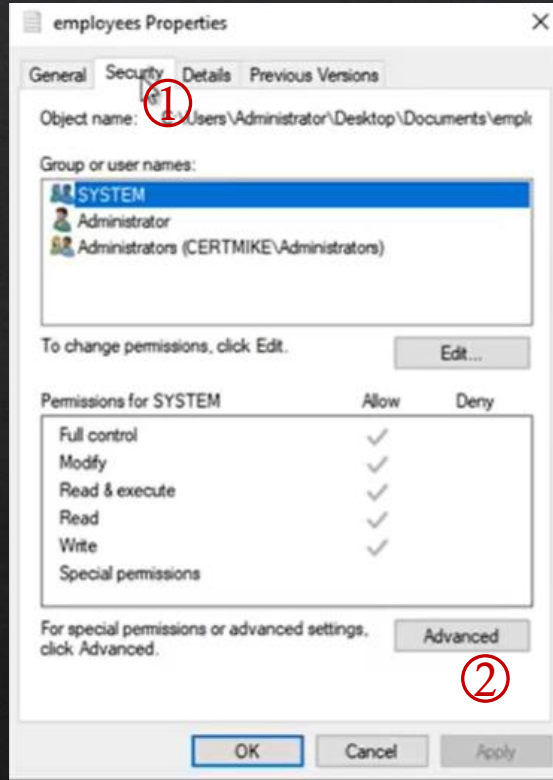
Others: r-x

Discretionary Access Control

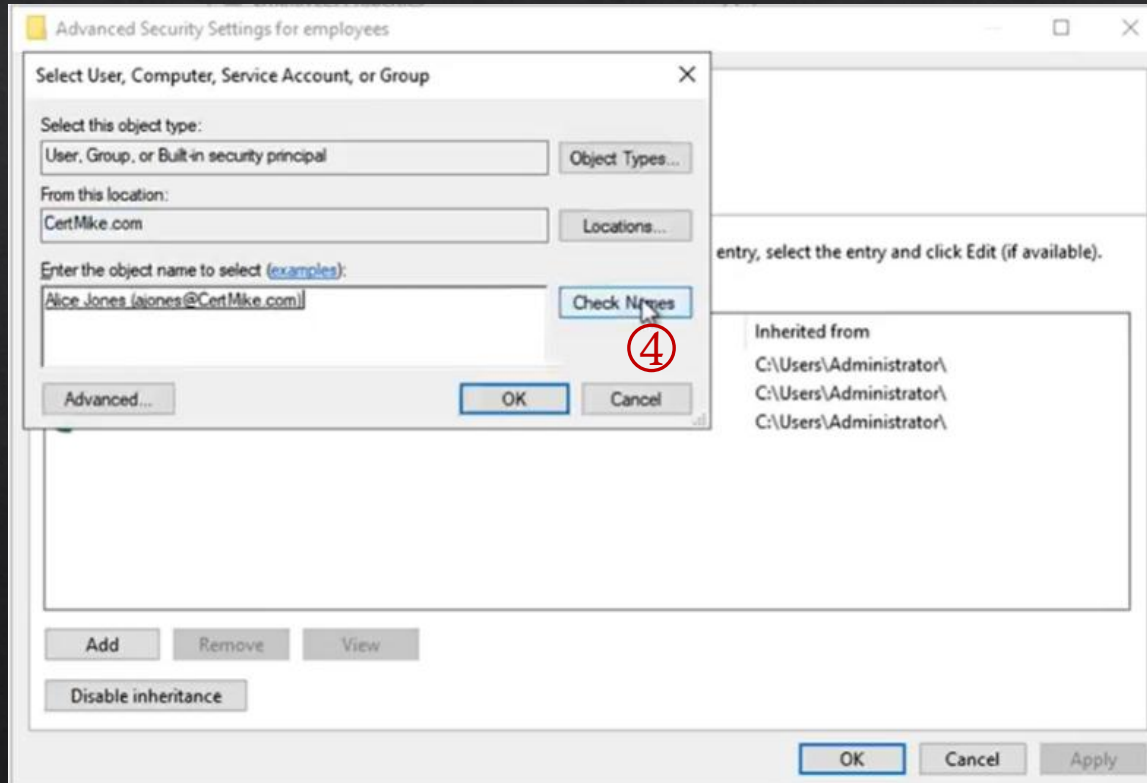
- ◇ Access control list
 - ◇ A table with username and permissions granted to each user on a resource



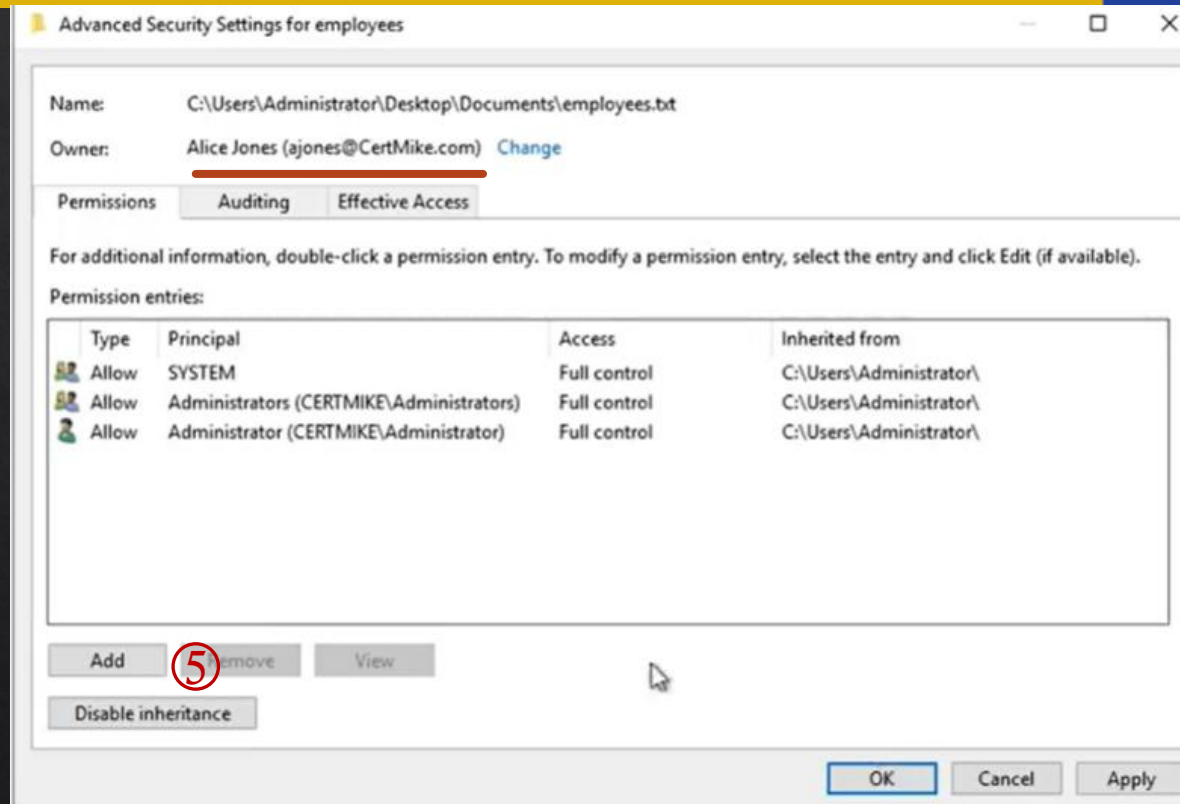
Discretionary Access Control



Discretionary Access Control



Discretionary Access Control



Discretionary Access Control

Permission Entry for employees

Principal: [Select a principal](#) ⑤

Type: Allow

Basic permissions:

- ☐ Full control
- ☐ Modify
- ☒ Read & execute
- ☒ Read
- ☐ Write
- ☐ Special permissions

Add a condition to limit access. The principal will be granted the specified permissions only if conditions are met.

Add a condition

Select User, Computer, Service Account, or Group

Select this object type:

User, Group, or Built-in security principal

Object Types...

From this location:

CertMike.com

Locations...

Enter the object name to select (examples):

Bob

Check Names

Advanced... ⑥

OK

Cancel

OK

Cancel

Discretionary Access Control

Permission Entry for employees

Principal: Bob Smith (rsmith@CertMike.com) [Select a principal](#)

Type: Allow

Basic permissions: [Show advanced permissions](#)

- ☒ Full control
- ☒ Modify
- ☒ Read & execute
- ☒ Read
- ☒ Write
- ☐ Special permissions

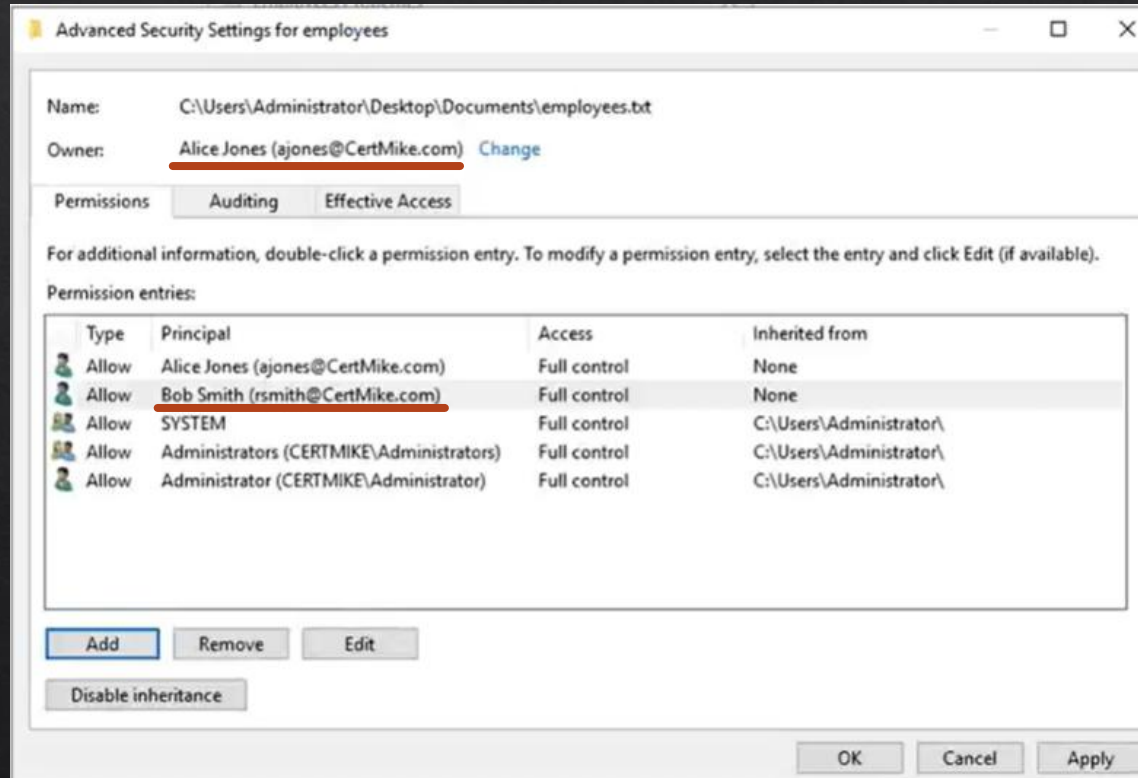
[Clear all](#)

Add a condition to limit access. The principal will be granted the specified permissions only if conditions are met.

[Add a condition](#)

[7](#) OK Cancel

Discretionary Access Control



Discretionary Access Control Types

Basic DAC

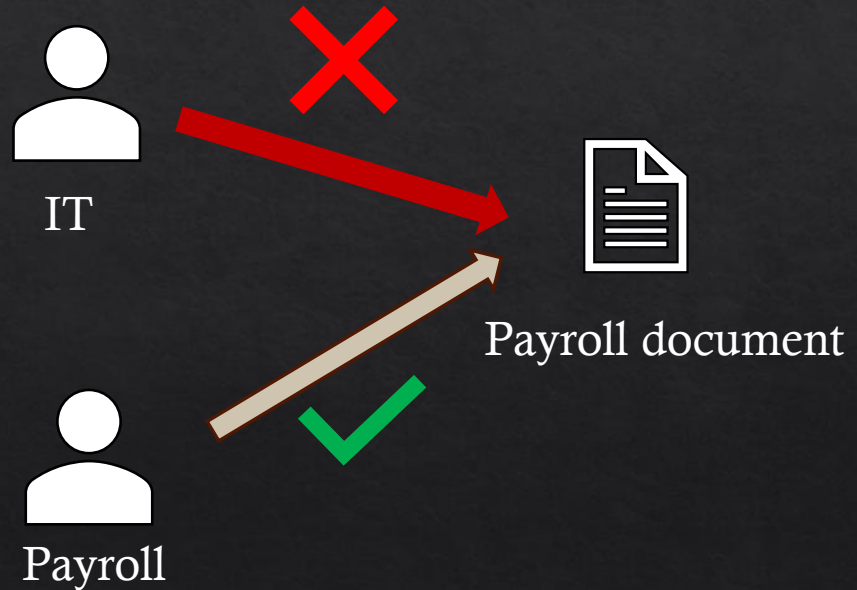
- ◇ A means of assigning access rights based on rights specified by the owner
- ◇ **No criterial or rule** to determine the access

Ruleset-based Access Control

- ◇ An access control framework which give data owners the discretion to determine the **rules** necessary to facilitate access
- ◇ For example, whether requester is from the same department (giving r/w) or not (only r)
- ◇ Compare with non-DAC? Ruleset is defined by the owner

Non-Discretionary Access Control

- ◆ **Role based access control:** Access decisions are based on the roles that users have as part of an organization
- ◆ Who owns the object (e.g., file) does not matter



Non-Discretionary Access Control Types

Content-Dependent Access Control

- ✧ Works by permitting or denying the subjects to access objects based on the **content** within the object
- ✧ For example, sensitivity level based

Context-Based Access Control

- ✧ Concerns only with the **context** or sequence of events surrounding the access attempt
- ✧ For example, Who? When? How? Why?
- ✧ Role based access control?

Non-Discretionary Access Control Types

Time-based Access control

- ◇ Time Limits (e.g., configuration change)
- ◇ Role-based?

Label-based Access Control

Attribute-based Access Control

Non-Discretionary Access Control Types

Time-based Access control

- ◇ Time Limits (e.g., configuration change)
- ◇ Role-based

Label-based Access Control

- ◇ Sensitivity labels
- ◇ Clearance

Attribute-based Access Control

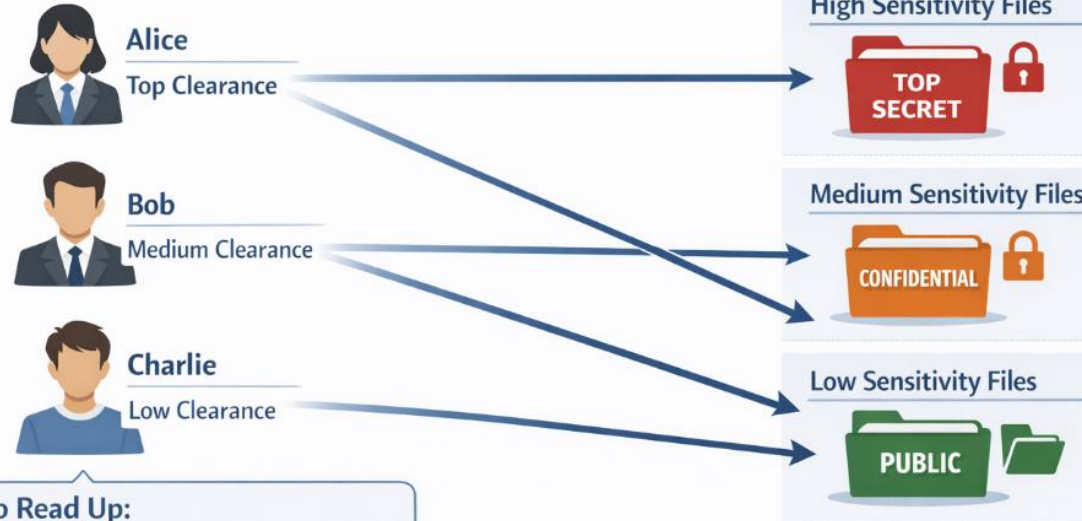
Non-Discretionary Access Control Types

Time

based
control

- ◇ Time
- ◇ Role

Sensitivity Label-Based Access Control



No Read Up:

Users can only access files at their clearance level or below

Non-Discretionary Access Control Types

Time-based Access control

- ◆ Time Limits (e.g., configuration change)
- ◆ Role-based

Label-based Access Control

- ◆ Sensitivity labels
- ◆ Clearance

Attribute-based Access Control

- ◆ Based on attribute of the subject
- ◆ Attributes can be e.g., department, location

Identity Management

- ◇ Identity Management Lifecycle
- ◇ Identity management types
- ◇ Identity and access interaction

Identity (and Access) Management (IAM)

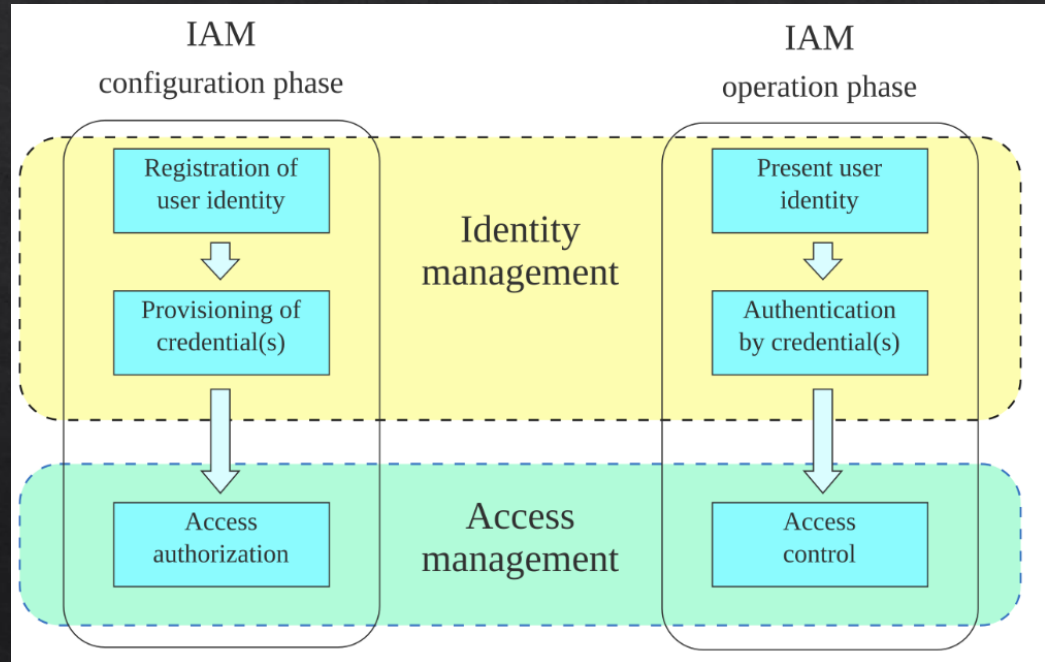
- ◇ A system to store all identity and access information
- ◇ Directory is created and maintained
- ◇ Manage lifecycle
 - ◇ Automated
 - ◇ Basic access control
- ◇ On-premises or Cloud-based
 - ◇ Active Directory (AD) is a Microsoft service (**server based**) that manages user identities, computers, and network resources in a centralized, hierarchical structure. It enables authentication (login) and authorization (permissions) for security, using tools like Domain Controllers to manage network resources.
 - ◇ Microsoft Entra ID is a cloud-based identity and access management (IAM) service used to manage user identities, credentials, and access to applications. It enables single sign-on (SSO), multi-factor authentication (MFA), and conditional access policies for Microsoft 365, Azure, and third-party apps.

<https://www.silverfort.com/glossary/active-directory/>

[https://en.wikipedia.org/wiki/Microsoft Entra ID](https://en.wikipedia.org/wiki/Microsoft_Entra_ID)

Identity (and Access) Management

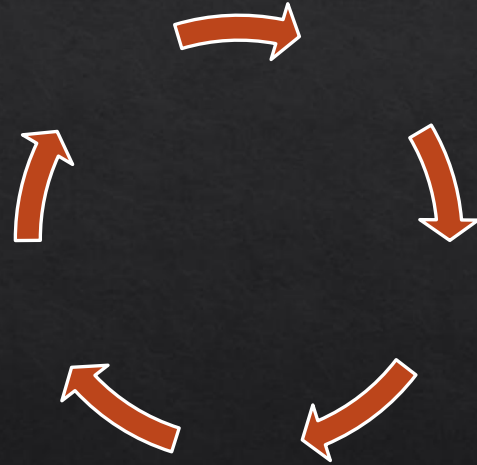
- Identity management (ID management) – or identity and access management (IAM) – is the organizational and technical processes for first registering and authorizing access rights in the **configuration phase**, and then in the **operation phase** for identifying, authenticating and controlling individuals or groups of people to have access to applications, systems or networks based on previously authorized access rights.



Identity (and Access) Management

Identity lifecycle includes creating, modifying, and finally retiring the identity of an authorized entity.

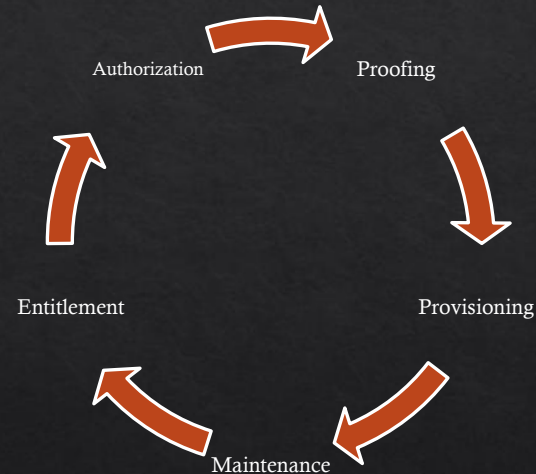
- ◇ Initial claim or proof (registration)
 - ◇ A user has to proof who they are
 - ◇ Create and authorize
- ◇ Monitor and Review
- ◇ Revocation
- ◇ Delete



Identity (and Access) Management

Main Tasks

- ❖ **Authorization:** Determines whether a user is permitted to access a particular resource
- ❖ **Proofing:** Verifies user's identities before accounts and credentials are issued
- ❖ **Provisioning:** Automation (or manually) of all procedures and tools
- ❖ **Maintenance:** User management, password management, and role/group management
- ❖ **Entitlement:** A set of rules for managing access to a resource and for what purpose



Identify Revocation vs Delete

Revocation

- ◆ Blocks identity from further usage
- ◆ Identity is still there in the directory

Delete

- ◆ Removes from the directory
- ◆ Most access related information (e.g., group, created file) are removed
- ◆ **Be cautious** (e.g., digital recovery, auditing)

Just-in-Time Provisioning

- ◇ JIT provisioning's primary purpose is to reduce administrative workload by eliminating the need for manual provisioning. Creates an account at the first login.
- ◇ Created at the time of access
 - ◇ Known as JIT identity
 - ◇ Websites, blogs, applications
 - ◇ Strong proofing not needed
- ◇ Standard Identity Assurance Level (IAL) is used
 - ◇ A category that conveys the degree of confidence that a person's claimed identity is their real identity, as defined in [NIST SP 800-63-3] in terms of three levels: IAL 1 (Some confidence), IAL 2 (High confidence), IAL 3 (Very high confidence)

https://csrc.nist.gov/glossary/term/identity_assurance_level

Standard IALs

IAL1

- ◆ **No effort needed to validate identity, self-asserted (e.g., email address)**
- ◆ Suitable for low-risk applications, such as social networks or general online forums.

IAL2

- ◆ **Validate claim, documented proofing methods**
- ◆ Appropriate for medium-risk scenarios, including financial transactions, healthcare services, and sensitive personal data access.

IAL3

- ◆ **In-person, supervised**
- ◆ Required physical validation including documents, biometric verification
- ◆ Required for high-risk environments, including government security clearances, access to highly sensitive healthcare records, or critical infrastructure systems.

Identity and AAA

- ◇ Tied with Authorization, Authentication and Accounting
- ◇ Determine Authentication
 - ◇ Single Factor
 - ◇ Multiple Factor
- ◇ Access control system defines capabilities
 - ◇ Assigning privileges during provisioning
 - ◇ Authorizing a specific access request

Identity and Access Control

- ◆ Centralized Access Control
 - ◆ One system having all identity and access information
 - ◆ All subjects and objects in one system
 - ◆ Either cloud based or on-premises
- ◆ Decentralized Access Control
 - ◆ Segments total set of subjects and objects
 - ◆ Access control in each partition (e.g., different databases)
 - ◆ Co-ordinate with one another

Protocol for IAM

- ◇ IAM protocols play a pivotal role in securing user identities and controlling access to resources.
- ◇ **Oauth 2.0**
 - ◇ OAuth 2.0 is a framework for delegated authorization, allowing third-party applications to access user resources without exposing user credentials. It is not an authentication protocol but is often used in conjunction with OIDC for that purpose.
- ◇ **Use Case:** A user wants to allow a third-party fitness app to access their health data stored in their smartphone's health app.
 - ◇ **1 Authorization Grant:** The user grants the fitness app access to their health data.
 - ◇ **2 Token Exchange:** The fitness app receives an authorization code from the identity provider, IdP (health app) and exchanges it for an Access Token.
 - ◇ **3 Resource Access:** The fitness app uses the Access Token to access the user's health data.

Protocol for IAM

◆ OpenID Connect (OIDC)

- ◆ OIDC is a simple identity layer on top of the OAuth 2.0 protocol, designed to verify user identities and obtain basic profile information. It is built for web and mobile applications, offering a straightforward approach to authentication.
- ◆ **Use Case:** A user wants to log into an online learning platform using their social media account.
 - ◆ **Metadata Exchange:** The RP (online learning platform) and IdP (social media platform) exchange minimal metadata, including client ID, secret, and endpoints.
 - ◆ **Authentication Request:** The RP redirects the user to the IdP with the client ID and requested scopes.
 - ◆ **User Authentication:** The IdP authenticates the user and obtains consent for sharing requested data.
 - ◆ **Token Issuance:** The IdP issues an ID Token and possibly an Access Token, which the RP uses to authorize resource access.

Protocol for IAM

- ◆ **SAML (Security Assertion Markup Language)**
 - ◆ SAML is an open standard that allows identity providers (IdPs) to pass authorization credentials to service providers (SPs). It was developed for **single sign-on (SSO)** to enhance user experience by reducing the need to remember multiple login credentials.
- ◆ **Use Case:** An employee needs to access the company's intranet and cloud-based applications like Salesforce and Workday.
 - ◆ **Metadata Exchange:** The SP (e.g., Salesforce) and IdP (e.g., the company's identity management system) exchange XML-based metadata to configure each other's endpoints, signing and encryption certificates, and supported protocols.
 - ◆ **Authentication Request:** The SP sends a SAML AuthnRequest to the IdP using HTTP POST or redirect binding.
 - ◆ **User Authentication:** The IdP authenticates the user (employee) and creates a SAML Assertion.
 - ◆ **Response and Assertion:** The IdP sends a SAML Response containing the Assertion back to the SP.
 - ◆ **Access Granted:** The SP parses the Assertion and grants or denies access based on the included attributes.
- ◆ **SAML vs OIDC:** enterprise and government applications vs web and mobile applications

Authentication

- ◇ Authentication concepts
- ◇ Authentication types
- ◇ Modern authentication concepts

Authentication Mechanism

Three Components

- ◆ **Identification:** (Who is the subject?)
 - ◆ Asserts a unique user or process identity and provides for accountability
- ◆ **Authentication:** (Proof of identity)
 - ◆ The process of verification that the identity presented to the access control system belongs to the party that has presented it
- ◆ **Authorization:**
 - ◆ What a user can do once they have been authenticated

Identification

- ◆ First step in the authentication mechanism:
 - ◆ Claiming to be someone and providing information
 - ◆ Most common types of identification (online website) are:
 - ◆ User ID (firstname.lastname? Any combination e.g., in E-commerce,)
 - ◆ PIN
 - ◆ Account Number

The image shows a login form on a white background. At the top left is the word "Login" in blue. Below it are two input fields: the first is labeled "Username" in a light yellow box, and the second is labeled "Password" in a white box with a red underline. Below the password field is a red error message: "Invalid username and/or password." Underneath the error message is a small circular icon with an 'i' followed by the text "By logging in, you agree to the [Terms of Service](#)." At the bottom right is a blue button with the word "LOGIN" in white capital letters.

Authentication

- ◇ Second identification step in authentication mechanism
 - ◇ To prove the user is who they say they are
 - ◇ Three factors:
 - ◇ Something you know
 - ◇ Something you have
 - ◇ Something you are
 - ◇ Activity, behaviour?

Authorization

- ◇ What the user can do once they are authenticated (Access control)
- ◇ Example (Authorization Table in DAC)

User	Object 1	Object 2	Object 3	Object 4
Alice	R	R	RW	RWX
Bob			WX	R
Charlie	RW	RW	RWX	X

Authentication Methods

Know

Have

Are

Authentication Methods

Know

- ◇ Password
- ◇ PIN



Strong password

- ◇ At least eight characters long
- ◇ Combination of digits, letters and symbols (**complex better?**)
- ◇ Password expiration (**should this be forced?**)
- ◇ Lock out after number of trials
- ◇ **Password manager**

Authentication Methods

Know

- ◇ Password
- ◇ PIN
- ◇ Lost? Leaked?

Have

- ◇ Tokens
- ◇ Smart Cards
- ◇ Badge

Are

- ◇ Biometrics

Authentication: Biometrics

- ◇ **Biometrics:** Technologies that measure and analyse human body characteristics for authentication purpose
 - ◇ DNA
 - ◇ Fingerprint (**stable?**)
 - ◇ Hand
 - ◇ Vascular
 - ◇ Facial pattern
 - ◇ Iris
- ◇ Two Types of biometrics:
 - ◇ Behavioural
 - ◇ Physiological

Authentication: Behavioural

- ◇ Something you are that is learned
 - ◇ Signature analysis
 - ◇ Keystroke
 - ◇ Voice pattern recognition
 - ◇ Movement
- ◇ **Voice Pattern Recognition:** Creating a collection of unique characters of the subject's voice. The subject then speaks and the voices are compared.



Measure Authentication Strength

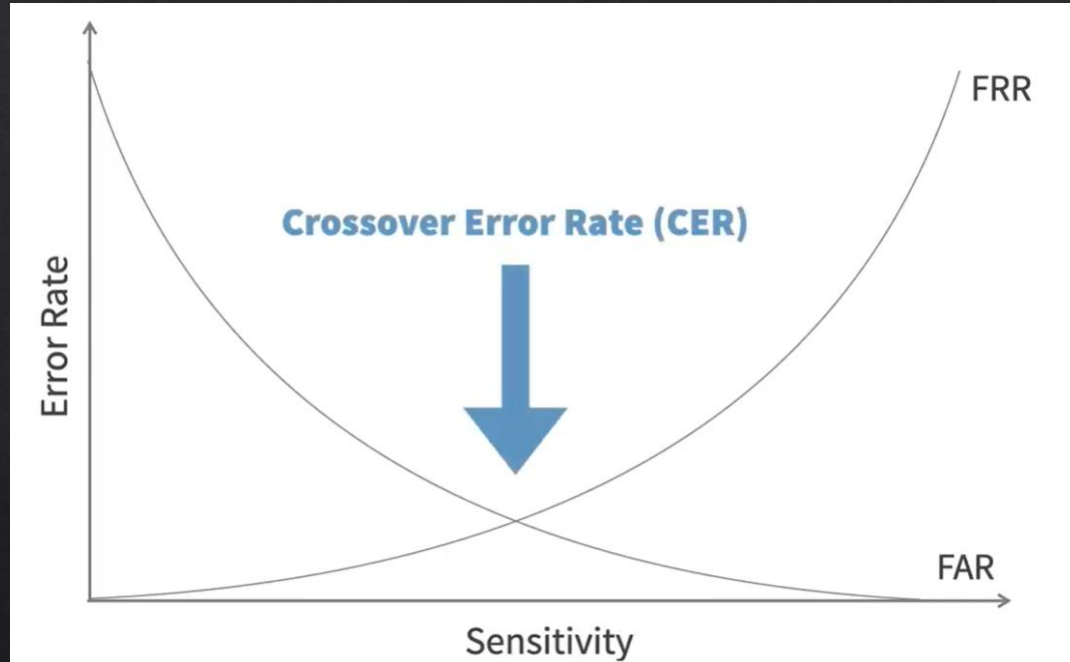
False Acceptance

- ◇ System misidentifies an individual as an authorized user
- ◇ Measured by the false acceptance rate (FAR)
- ◇ Security issue

False Rejection

- ◇ System fails to recognize an authorized user
- ◇ Measured by the false rejection rate (FRR)
- ◇ Usability issue

Measure Authentication Strength



There is always a tradeoff between FAR and FRR

Multi-Factor Authentication (MFA)

- ◆ Authentication uses three factors:
 - ◆ You know
 - ◆ You have
 - ◆ You are
- ◆ **MFA:** Any two or three of the factors
 - ◆ Using a password and a smartcard
- ◆ **NOT** MFA
 - ◆ Using a fingerprint scan and facial recognition
 - ◆ Two passwords



Single-Sign On (SSO)

- ◇ SSO: An authentication mechanism that allows a single identity to be shared across multiple applications. It allows a user to authenticate once and gain access to multiple resources or even multiple platforms
 - ◇ Google (email, Youtube, Google Drive)
 - ◇ Microsoft Office
 - ◇ Meta
- ◇ **MFA can be always combined with SSO**

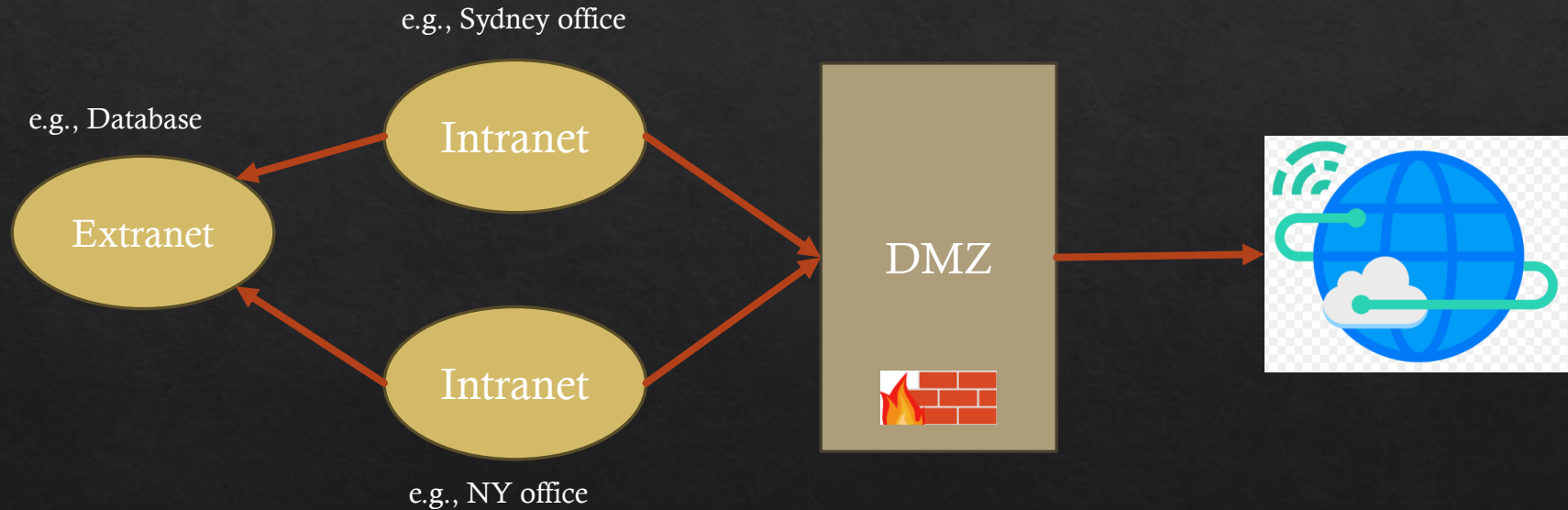
Trust Architecture

- ◇ Basic Concepts of Trust Architectures
- ◇ Trust Direction
- ◇ Zero Trust

Trust Architecture

- ◇ Computers are connected by networks, and different kinds of networks give various levels of trust
- ◇ Four types of Trust architecture:
 - ◇ Internet
 - ◇ Intranet
 - ◇ Extranet
 - ◇ Demilitarized Zone (DMZ)

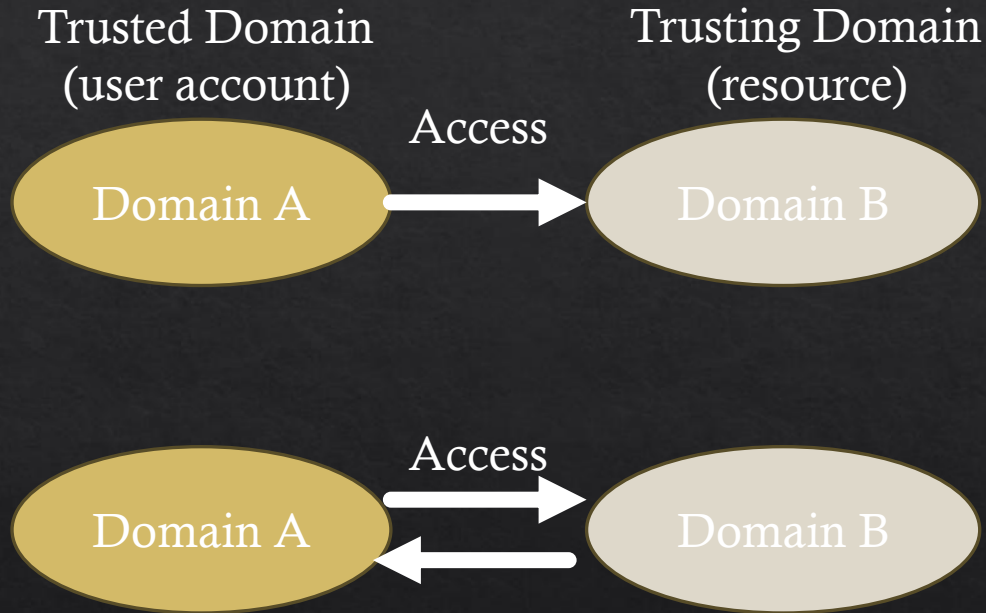
Trust Architecture



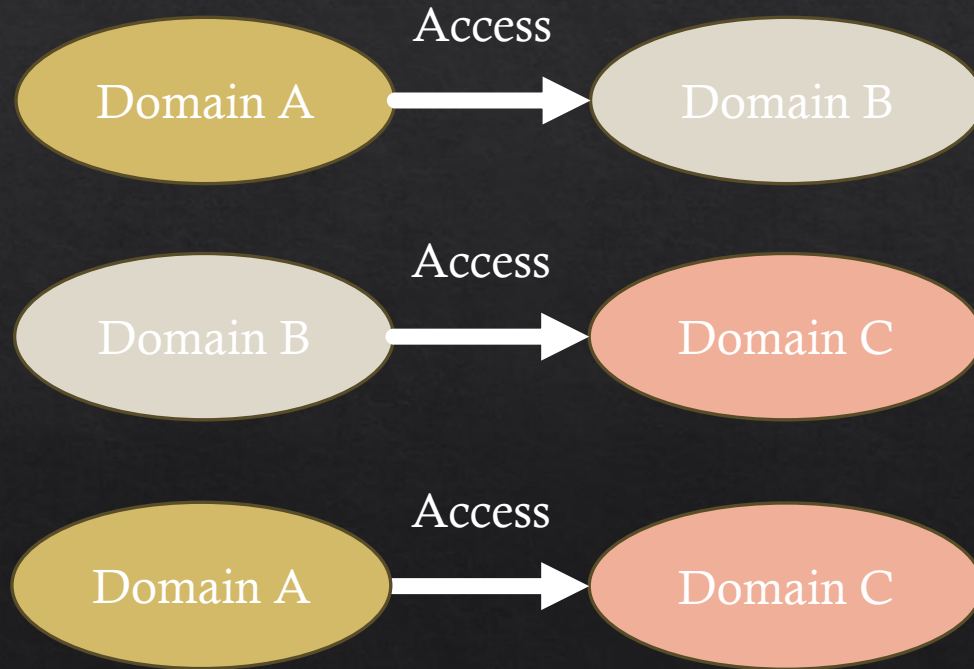
Trust Direction

- ◇ Trust: The belief in the security of a connection between domains
- ◇ Trust Path: A series of trust relationships that authentication requests must follow between domains
- ◇ Kinds of Trust include:
 - ◇ One-way Trust
 - ◇ Two-way Trust
 - ◇ Trust Transitivity

Trust Direction



Trust Transitivity



Zero Trust

- ◆ A **security principle**: Assuming breach can happen anytime within your
 - ◆ Network
 - ◆ User
 - ◆ Domain
- ◆ Requires constant validation

Implementing Zero Trust

- ◆ Just in time access (JIT), **When**
 - ◆ Focuses on limiting the duration of access. Privileges are granted on-demand, usually via approval, and automatically revoked after a set time.
- ◆ Just enough access (JEA), **What**, “Principle of Least Privilege”
 - ◆ Focuses on limiting the scope of permissions. Users receive only the exact, minimal permissions required for their specific tasks.
- ◆ Real-time access policies, **Speed**
 - ◆ Refers to the instantaneous provisioning of either JIT or JEA privileges. It is the speed at which the access is granted upon request.
- ◆ Modern security solutions

Conclusion

- ◆ Access control concepts and types
- ◆ Identity management
- ◆ Authentication methods
- ◆ Trust architecture

Acknowledge: ISC2 Systems Security Certified Practitioner (SSCP) Cert Prep,
from LinkedIn Learning, instructor Seema Rahman

References

- ◇ ISC Security Crunch
- ◇ Tal Garfinkel
- ◇ Microsoft Cybersecurity Solutions Group

Additional Resources

- ◇ Capabilities
 - ◇ <https://people.cs.rutgers.edu/~pxk/419/notes/confinement.html>
- ◇ Azure AD and ADFS best practices
 - ◇ <https://cloudblogs.microsoft.com/enterprisemobility/2018/03/05/azure-ad-and-adfs-best-practices-defending-against-password-spray-attacks/>
- ◇ Microsoft Password Guidance
 - ◇ <https://aka.ms/passwordguidance>
- ◇ NIST Updated Password Guidance
- ◇ Access Control Explained (Video)
 - ◇ <https://www.youtube.com/watch?v=hlbRzgg3lac>
- ◇ Ignite Session: Azure Active Directory risk-based identity protection
 - ◇ <https://channel9.msdn.com/events/Ignite/Microsoft-Ignite-Orlando-2017/BRK3016>